

CommunitySafe: Uma Abordagem Integrada de Segurança, Privacidade e Engajamento Comunitário

Documentação Técnico-Científica e Arquitetural do Projeto Integrador

Projeto Integrador de Políticas de Segurança da Informação

3 de junho de 2026

Resumo

O presente documento detalha a fundamentação teórica, as decisões arquiteturais e as implementações técnicas da plataforma *CommunitySafe*. Concebida como um ecossistema digital composto por uma API de retaguarda (Backend) e uma aplicação móvel cliente (Frontend), a solução propõe uma infraestrutura para serviços comunitários que integra nativamente os paradigmas de *Security by Default* e *Privacy by Design*. A arquitetura harmoniza tecnologias de ponta — como .NET 8 e 9, PostgreSQL com PostGIS para processamento geo-espacial e criptografia de grau militar — com rigorosos requisitos de conformidade com a Lei Geral de Proteção de Dados (LGPD). O estudo demonstra como as políticas de segurança da informação podem ser materializadas no código-fonte, garantindo a proteção do utilizador sem comprometer a usabilidade e a adoção em contextos de vulnerabilidade socioeconômica.

1 Introdução e Referencial Conceitual

A plataforma *CommunitySafe* emerge da necessidade de mitigar as vulnerabilidades sociais através do fomento do engajamento comunitário, facilitando a organização de eventos, campanhas de voluntariado e recolha de donativos. Contudo, a transação de dados pessoais num ambiente comunitário exige uma infraestrutura que garanta, acima de tudo, a confidencialidade, a integridade e a disponibilidade da informação.

O aspeto conceitual do projeto transcende o desenvolvimento de software tradicional ao considerar, primariamente, o perfil socioeconómico do público-alvo. A decisão por uma abordagem estritamente *mobile-first*, com forte priorização do ecossistema Android, reflete uma leitura empírica da realidade tecnológica de países em desenvolvimento, onde o *smartphone* atua, na larga maioria das vezes, como o único vetor de acesso à Internet em áreas periféricas. Desta forma, a engenharia de *software* aplicada foi orientada para oferecer resiliência em cenários de conectividade intermitente (operações *offline-first*), baixa fricção cognitiva e alta acessibilidade.

2 Arquitetura de Software e Decisões de *Design*

O sistema adota uma arquitetura distribuída e desacoplada, segregando por completo a lógica de negócios e a persistência de dados (Backend) da interface de utilizador (Frontend Mobile). Esta separação, refletida em repositórios e ciclos de compilação (*build*) independentes, é uma decisão de segurança por excelência: previne a exposição de binários do núcleo do sistema aos clientes e impede a engenharia reversa das regras de negócio críticas.

2.1 Backend (*CommunitySafe.Api*)

Construído sobre a *framework* .NET 8 (ASP.NET Core) e utilizando o *Entity Framework Core 8* como mapeador objeto-relacional (ORM), o backend opera como a fonte única de verdade e o árbitro das autorizações de domínio. A persistência de dados utiliza PostgreSQL acoplado à extensão PostGIS. A integração do PostGIS, suportada pela biblioteca *NetTopologySuite*, é o alicerce que viabiliza o mapeamento espacial através do tipo *geography(Point,4326)*. Esta modelação permite a execução de consultas otimizadas baseadas em raios de proximidade (*ST_DWithin*), um recurso indispensável para a funcionalidade central do sistema: um *feed* de eventos filtrado pela proximidade geográfica do utilizador.

2.2 Frontend Mobile (*CommunitySafe.Mobile*)

Desenvolvido em .NET MAUI 9, utilizando a linguagem C# e XAML, o cliente consolida bases de código para Android, iOS, Windows e Mac. A aplicação adota o padrão arquitetural MVVM (*Model-View-ViewModel*). Uma decisão pedagógica e arquitetural de relevo foi a implementação do MVVM de forma “manual” (sem a injeção de bibliotecas de geração de código como o *CommunityToolkit.Mvvm*). Esta abordagem garante total transparência no fluxo de ligação de dados (*DataBinding*) e execução de comandos, permitindo que a auditoria do código fonte seja clara e linear.

A comunicação HTTP é mediada por rotinas customizadas (*DelegatingHandlers*), que injetam automaticamente *tokens* de acesso (*Bearer*) e gerem interceções de erros de autorização (ex.: código 401), purgando automaticamente o armazenamento local para forçar uma re-autenticação segura.

3 Políticas de Segurança da Informação Integradas

A segurança é o pilar estrutural do *CommunitySafe*, sendo tratada não como um requisito não funcional periférico, mas como parte intrínseca do domínio de negócio. O projeto implementa princípios de *Defense in Depth* (Defesa em Profundidade) através das seguintes camadas:

- **Criptografia de Dados em Repouso e em Trânsito:** As senhas dos utilizadores são protegidas pelo algoritmo adaptativo *BCrypt* (com um *work factor* de 12), oferecendo elevada resistência a ataques de força bruta. Dados sensíveis do sistema, como chaves mestras para geração de *Tokens* Baseados em Tempo (TOTP) da Autenticação de Dois Fatores (2FA),

são cifrados utilizando a cifra autenticada AES-256-GCM. Em trânsito, a aplicação móvel impõe, através do seu *Network Security Config*, o bloqueio estrito a tráfego HTTP em texto limpo.

- **Gestão de Identidade e Sessões:** A arquitetura *stateless* baseia-se em *JSON Web Tokens* (JWT) assinados via HS256. Foi implementada uma política de expiração curta (15 minutos) complementada por um mecanismo de *Refresh Tokens* com duração de 7 dias. Este mecanismo inclui *Rotation* e **detenção de reuso por FamilyId**, revogando toda a cadeia de sessão caso um *token* já consumido tente ser reutilizado, prevenindo eficazmente o sequestro de sessões.
- **Proteção Contra Abusos (Rate Limiting):** Integrações com APIs externas, como o *lookup* de códigos postais (BrasilAPI/ViaCEP), estão protegidas por limitadores de taxa (30 requisições por minuto por IP) para mitigar tentativas de *scraping* ou exaustão de recursos (DoS).

4 Conformidade Regulatória: A LGPD como Contrato de Domínio

O projeto destaca-se por transformar os requisitos legais da Lei Geral de Proteção de Dados (LGPD) em entidades de domínio de *software*. A tabela abaixo resume o mapeamento técnico-legal implementado:

Artigo LGPD	Mecanismo Técnico Implementado
Art. 6º (Minimização)	Recolha estrita dos dados necessários à operação. Campos opcionais e validações rigorosas nos <i>Data Transfer Objects</i> (DTOs).
Art. 7º e 8º (Consentimento)	Registo granular e independente para 4 eixos (Cadastro, Geolocalização, Notificações, Marketing). A entidade <i>ConsentRecord</i> mantém o histórico de concessões e revogações com carimbo de tempo.
Art. 16 (Retenção Legal)	A eliminação de conta aciona um <i>Soft Delete</i> ao invés de um <i>CASCADE DELETE</i> . Os dados operacionais necessários à auditoria são anonimizados ou retidos legalmente, ocultando o perfil da interface pública.
Art. 18 (Direitos do Titular)	<i>Endpoints</i> dedicados permitem que a aplicação móvel extraia um <i>snapshot</i> completo em formato <i>JSON</i> com todo o rastro de dados do titular, viabilizando o direito à portabilidade.
Art. 37 (Auditoria e Logs)	Implementação do <i>AuditLog</i> como estrutura estritamente <i>append-only</i> . Modificações ou deleções nos registos de auditoria são sumariamente bloqueadas na camada aplicacional (<i>AppDbContext.SaveChanges</i>) e na base de dados (Gatilhos SQL restritivos).

5 Controlo de Acesso Baseado em Papéis (RBAC) e Experiência do Utilizador

A plataforma gere o acesso através de uma hierarquia rigorosa de papéis: *Pessoa Física*, *Pessoa Jurídica*, *Síndico* e *Administrador*. As permissões são sempre validadas do lado do servidor (e.g., apenas *Síndicos* ou *Administradores* podem gerar códigos de convite para a sua comunidade).

Para garantir uma interface de utilizador fluida e livre de frustrações (*UX Inclusivo*), o cliente móvel descodifica a *claim* do papel do utilizador a partir do *payload* do JWT (um processo local e síncrono). Com base nesta leitura, a aplicação oculta ou inativa preventivamente opções de interface que resultariam em erros de acesso negado (Erro 403 - *Forbidden*), tais como botões de criação de eventos para contas de perfis sem privilégios.

6 Considerações Finais

A conceção e implementação do ecossistema *CommunitySafe* demonstram a viabilidade prática de unir o rigor académico em segurança cibernética com o desenvolvimento de uma aplicação orientada ao impacto social. Ao aliar o PostGIS para funcionalidades de comunidade baseadas em localização com uma matriz severa de controlos criptográficos e arquitetura defensiva, o projeto estabelece uma fundação robusta, escalável e, acima de tudo, garante a dignidade digital e a privacidade dos seus utilizadores.